

PHP MySQL Prepared Statements

Prepared Statements

- a feature used to execute the same (or similar) SQL statements repeatedly with high efficiency.
- basically work like this:
 - 1. **Prepare**: An SQL statement template is created and sent to the database. Certain values are left unspecified, called parameters (labeled "?"). Example:
INSERT INTO MyGuests VALUES(?, ?, ?)
 - 2. **The database parses, compiles, and performs query optimization on the SQL statement template, and stores the result without executing it**
 - 3. **Execute**: At a later time, the application binds the values to the parameters, and the database executes the statement. The application may execute the statement as many times as it wants with different values
- **Three advantages:**
 - **reduce parsing time**
 - **Bound parameters minimize bandwidth** to the server as you need send only the parameters each time, and not the whole query

Example (MySQLi with Prepared Statements)

```
<?php
$servername = "localhost";
$username = "username";
$password = "password";
$dbname = "myDB";

// Create connection
$conn = new mysqli($servername, $username, $password,
$dbname);

// Check connection
if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
}

// prepare and bind
$stmt = $conn->prepare("INSERT INTO MyGuests (firstname,
lastname, email) VALUES (?, ?, ?)");
$stmt->bind_param("sss", $firstname, $lastname, $email);

// set parameters and execute
$firstname = "John";
$lastname = "Doe";
$email = "john@example.com";
$stmt->execute();
```

```
$firstname = "Mary";
$lastname = "Moe";
$email = "mary@example.com";
```

```
$stmt->execute();
```

```
$firstname = "Julie";
$lastname = "Dooley";
$email = "julie@example.com";
$stmt->execute();
```

```
echo "New records created successfully";
```

```
$stmt->close();
$conn->close();
?>
```

The s character tells mysql that the parameter is a string.

The argument may be one of four types:

- i - integer
- d - double
- s - string
- b - BLOB

Parameterized queries in PHP with MySQL connection

- <https://stackoverflow.com/questions/36366754/parameterized-queries-in-php-with-mysql-connection>

- Example: **//conventional query**

```
$userName = $_POST["username"];
$userPass = $_POST["password"];
$query = "SELECT * FROM users WHERE username = '$userName' AND password = '$userPass'";
$result = mysqli_query($dbc, $query); // $dbc is for MySQL connection: $dbc =
    @mysqli_connect($dbhost, $dbuser, $dbpass, $db)
$row = mysqli_fetch_array($result);
if(!$row){
    echo "No existing user or wrong password.";
}
```

- **Prepare statement**

```
$stmt = mysqli_prepare($dbc, "SELECT * FROM users WHERE username = ? AND
password = ?");
mysqli_stmt_bind_param($stmt, "s", $userName);
mysqli_stmt_bind_param($stmt, "s", $userPass);
mysqli_stmt_execute($stmt);
$row = mysqli_stmt_fetch($stmt);
```